

Karta testów bezpieczeństwa radiowego

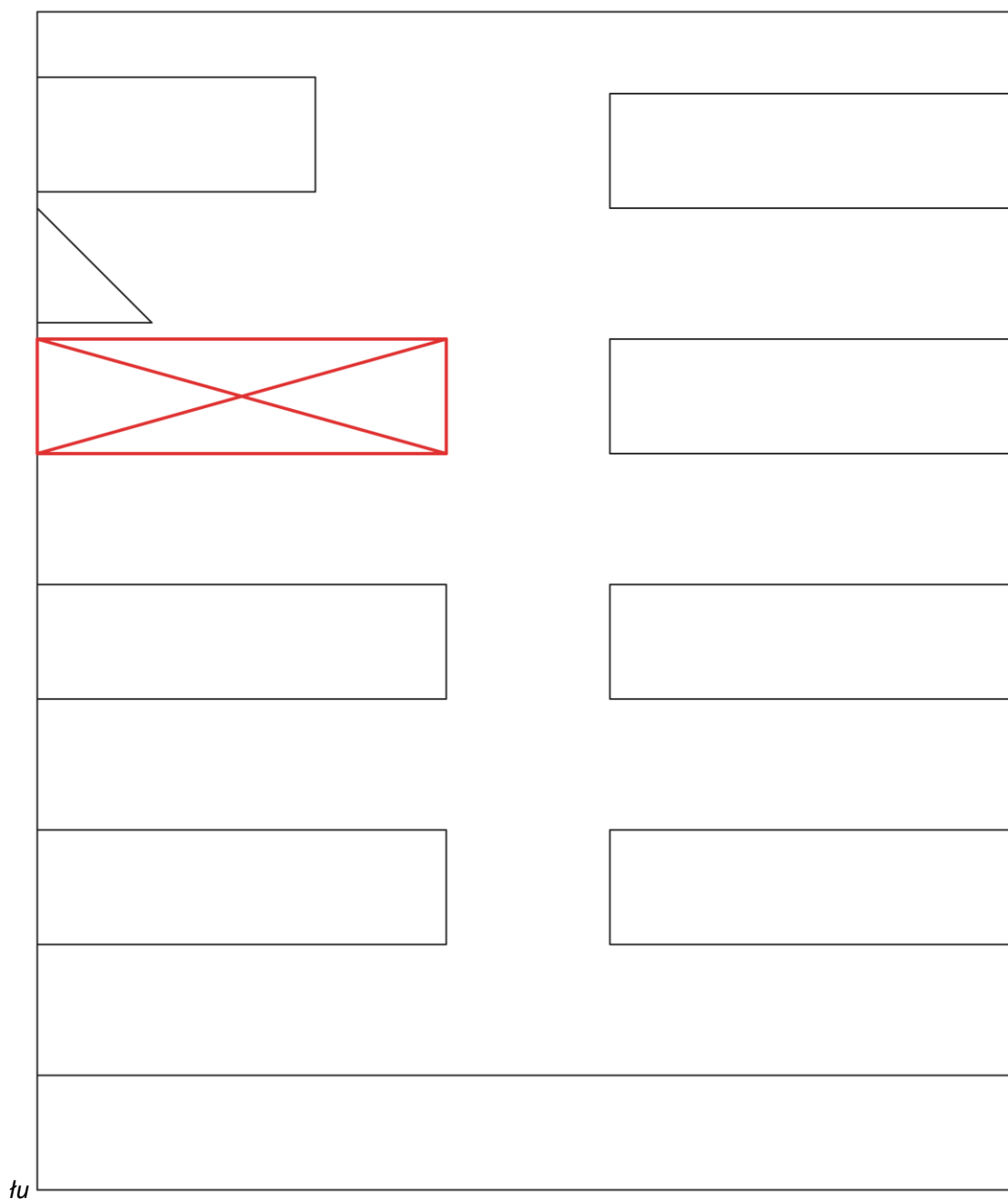
BEKO 2025L

Autorzy: Wiktor Sosnowski, Michał Lejwoda, Krzysztof Kulesza

Uwagi:

1. Do badań należy użyć następującego zestawu narzędzi: PlutoSDR + SigDigger / Audacity / GNURadio / Inspectrum / rtl_433.
2. Badania należy udokumentować w sposób pozwalający na ich odtworzenie – tj. opisać zastosowane procedury, zamieścić schematy blokowe i ewentualnie fotografie stanowisk pomiarowych, wykresy widm, oscylogramy, obliczenia, komentarze i wnioski.
3. Należy pamiętać o skasowaniu przykładów zamieszczonych w niniejszym szablonie.
4. Należy pilnować numeracji rysunków.
5. Odstępy pozostawione w niniejszym szablonie na komentarze i rysunki nie sugerują objętości komentarzy czy rozmiaru rysunków, które należy dobierać stosownie do przekazywanej treści.
6. Należy zadbać o rozsądny rozmiar dokumentu (w MB). Jakość fotografii i ogólnie wszystkich elementów graficznych będzie uznawana za wystarczającą, jeśli zapewni czytelność Karty po wydrukowaniu jej w formacie A4.
7. Kartę do sprawdzenia i oceny należy dostarczyć w formacie pdf.

1. Lokalizacja stanowiska pomiarowego



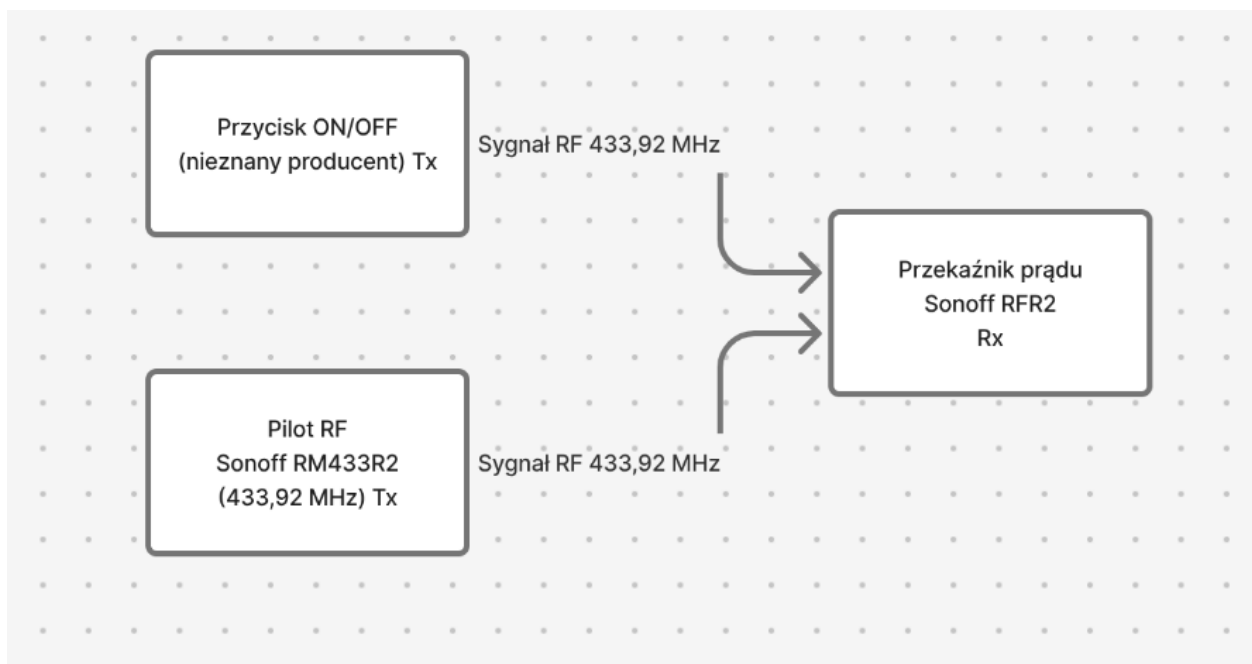
Rys .1.1 Lokalizacja stanowiska pomiarowego w laboratorium

2. Opis przedmiotu badań.

Nazwa i krótki opis systemu stanowiącego przedmiot badań:

Sterownik przełącznika prądu firmy sonoff, sterowany przyciskiem(nieznanego producenta) oraz pilota rf sonoff.

Rys. 2.1 Schemat blokowy systemu stanowiącego przedmiot badań



Elementy składowe systemu (z odniesieniami do rys.2.1):

- *Pilot wyposażony w 8 przycisków Tx.*
- *Przycisk on/off Tx*
- *Przełącznik prądu Rx*

Specyfikacja poszczególnych elementów systemu:

Przełącznik prądu firm: sonoff, model RFR2, obsługiwany protokół: wifi 2.4GHz, Input 100-250VAC 50/60Hz 10 A, Output 100-240 VAC 50/60Hz, RF: 433,92 MHz.

Pilot firmy sonoff model RM433R2, Zasilanie 3V, RF:433MHZ

Przycisk: brak możliwości określenia informacji.

Słowny opis funkcjonalności:

System składa się z Przełącznika prądu firmy Sonoff odbierającego sygnał z pilota sonoff oraz przycisku(nieznany producent). Działanie polega na odbieraniu przez przełącznik sygnału ze strony pilota oraz przycisku w którym za pomocą klikania poszczególnych przycisków na pilocie oraz klikania przycisku jesteśmy w stanie włączyć bądź wyłączyć przełącznik który możemy użyć np. do zasilania lampki nocnej.

Czy system jest autonomiczny:

System wydaje się być autonomiczny ze względu na to, że możliwe jest sterowanie nim za pomocą dwóch modułów: przełącznika oraz do wyboru przycisku lub pilota.

Informacje o dostępnej dokumentacji i certyfikatach:

Producent udostępnia instrukcję obsługi online dla przełącznika:

<https://help.sonoff.tech/docs/rfr2>

Produkt posiada certyfikaty: ETL/CE/FCC/RoHS

Producent udostępnia instrukcję obsługi dla pilota:

https://cdn.shopify.com/s/files/1/0742/9963/8001/files/User_Manual_RM433R2_V1.1.pdf?v=1748505919

Czy system może być legalnie używany na terenie Polski?

Tak, sprzedawany w mediaexpert, więc dział prawny na pewno zadbał o to, żeby sprawdzić czy legalność użytkowania tego urządzenia w Polsce nie narusza żadnych przepisów.

Dodatkowe informacje o systemie:

Dodatkowe informacje o systemie

Poniżej zebrane informacje z publicznie dostępnych źródeł dotyczące znanych słabości, ataków i nietypowych zachowań systemu opartego na urządzeniach Sonoff oraz protokole 433 MHz.

1. Podatność na atak typu Replay Attack (RF 433 MHz)

Jest to najpoważniejsza słabość kanału radiowego stosowanego w tym systemie. Dane przesyłane przez urządzenia 433 MHz są często transmitowane jako plaintext (bez szyfrowania), co czyni je podatnymi na przechwycenie i ataki typu replay przy użyciu prostych narzędzi do analizy widma. [MOES Smart](#)

Przy użyciu odbiornika RTL-SDR, Raspberry Pi i kawałka drutu jako anteny możliwe jest przeprowadzenie ataku replay na proste sygnały cyfrowe stosowane w urządzeniach ISM 433 MHz – takich jak przełączniki bezprzewodowe – co pozwala napastnikowi zdalnie je kontrolować. [rtl-sdr.com](#)

Podstawowe systemy 433 MHz używające statycznych kodów są podatne na ataki replay, w których sygnał jest przechwytywany, a następnie odtwarzany. Nowsze systemy stosują technologię rolling code lub szyfrowanie AES-128 w celu zwiększenia bezpieczeństwa. [Accio](#) Sonoff RM433R2 nie korzysta z rolling code, co oznacza, że jest podatny na tego rodzaju atak.

Źródła: [rtl-sdr.com](#), [moeshouse.com](#), [researchgate.net](#)

2. Podatność platformy eWeLink / Sonoff – zdalne przejęcie urządzenia

Firma Bitdefender wykryła podatność w platformie ITEAD Sonoff / eWeLink, która zarządza zdalnym sterowaniem przełącznikami i gniazdami. Wykorzystanie tej luki pozwala potencjalnemu atakującemu przejść kontrolę nad losowo wybranymi urządzeniami i zdalnie wykonywać dostępne przez nie funkcje. [Bitdefender](#)

Źródło: [bitdefender.com](#)

3. Słabe hasło domyślne i nieszyfrowany ruch HTTP

W trakcie parowania urządzenie Sonoff rozgłasza własną sieć WiFi zabezpieczoną domyślnym hasłem PSK równym 12345678, które producent jawnie opublikował w instrukcji obsługi. Ponadto ruch między wtyczką a aplikacją mobilną podczas konfiguracji odbywa się po nieszyfrowanym HTTP, co umożliwia przechwycenie danych uwierzytelniających sieci WiFi użytkownika. [A&O IT Group](#)

Atakujący w zasięgu routera może przechwycić dane logowania do sieci WiFi użytkownika i wykorzystać je do atakowania innych urządzeń w sieci domowej lub przeprowadzenia ataków botnetowych na inne systemy w Internecie. [CNX Software](#)

Źródła: [goitgroup.com](#), [cnx-software.com](#)

4. Możliwość instalacji złośliwego firmware

Obudowa urządzeń Sonoff jest bardzo łatwa do demontażu i złożenia bez pozostawiania śladów. Badaczom bezpieczeństwa udało się zainstalować złośliwe oprogramowanie firmware i umieścić zmodyfikowane urządzenie z powrotem w łańcuchu dostaw. W ten sposób urządzenie mogło ujawniać lokalizację geograficzną ofiary (przez BSSID) i umożliwiać przeprowadzanie ataków z sieci WiFi ofiary.

[A&O IT Group](#)

Mechanizm aktualizacji OTA (Over-The-Air) urządzeń Sonoff nie weryfikuje podpisu cyfrowego przesyłanego firmware'u, co umożliwia jego podmianę przez atakującego kontrolującego ruch sieciowy.

[Hackaday](#)

Źródła: [aoitgroup.com](#), [hackaday.com](#)

5. Nieszyfrowane połączenia z zewnętrznymi serwisami analitycznymi

Choć połączenie między przekaźnikiem Sonoff a chmurą producenta jest szyfrowane przez TLS 1.2, po zamknięciu aplikacji nawiązywane są nieszyfrowane połączenia – głównie z serwisami analitycznymi firm Tencent i Xiaomi. Brak implementacji certificate pinning oznacza, że zaszyfrowane części ruchu są chronione tylko przed prostymi atakami man-in-the-middle. [lot-tests](#)

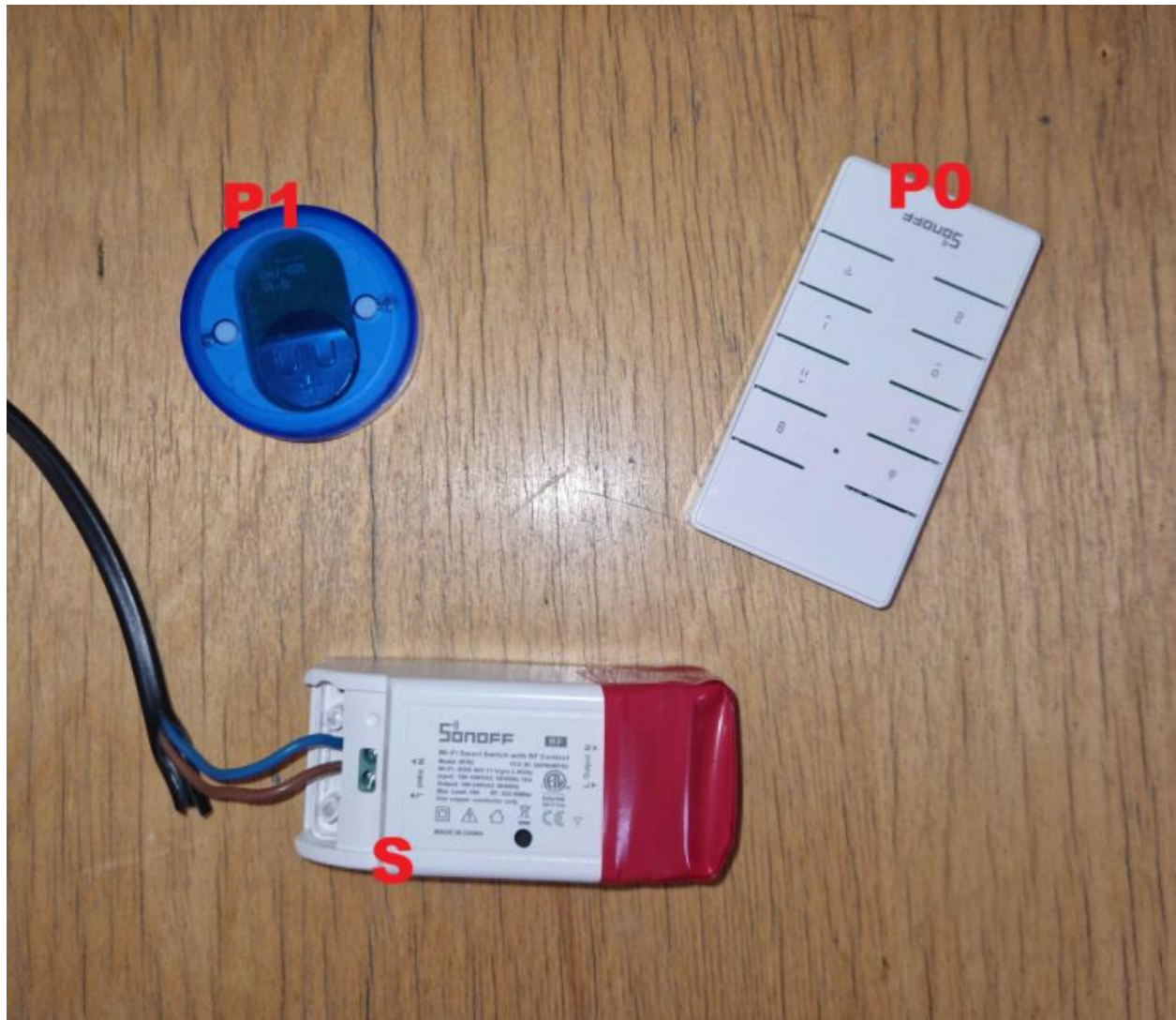
Źródło: [iot-tests.org](#)

6. Podatność na zakłócenia (jamming) kanału 433 MHz

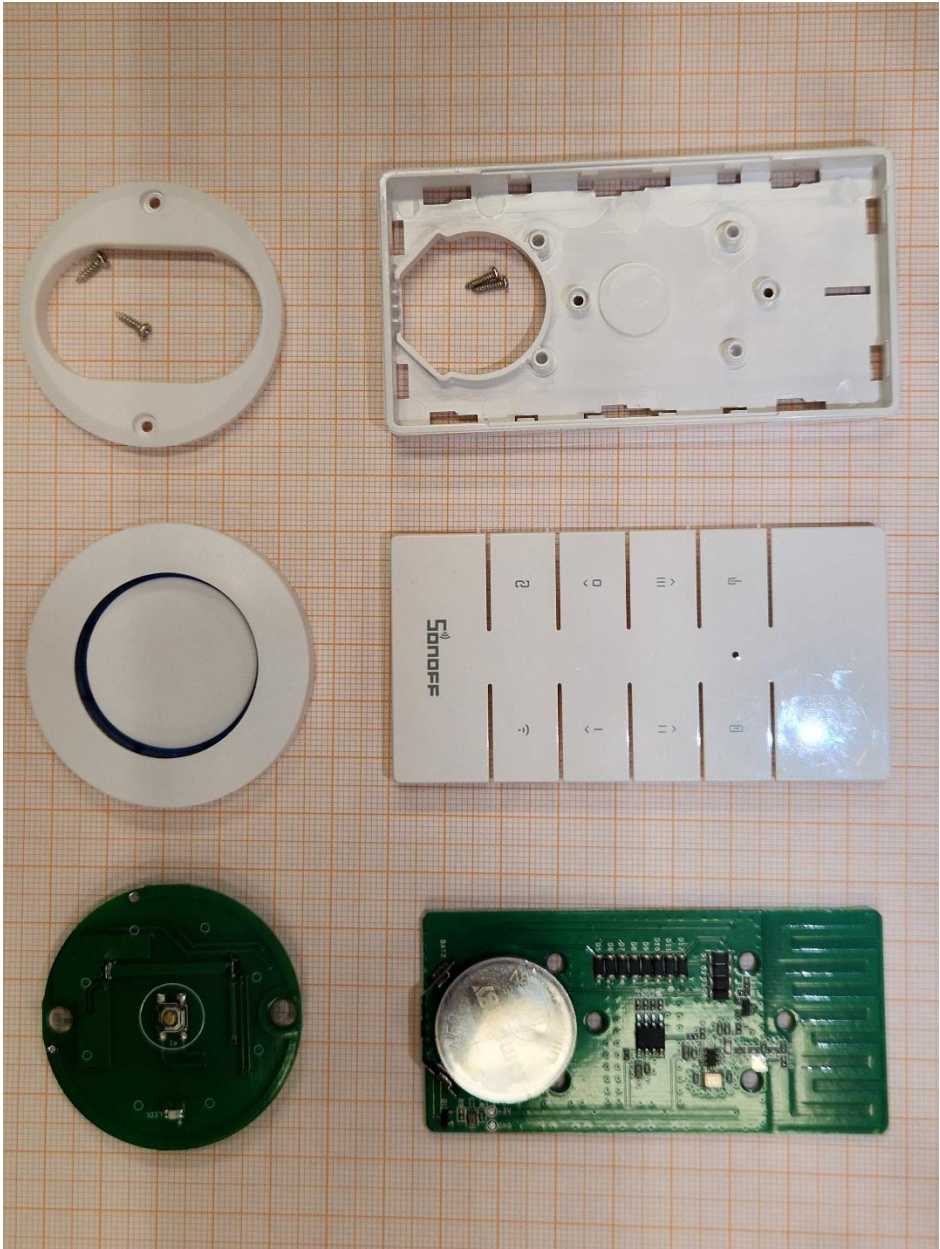
Pasmo 433 MHz nie dysponuje mechanizmami mitygacji zakłóceń, takimi jak frequency hopping czy korekcja błędów. Gdy wiele urządzeń nadaje jednocześnie na zbliżonych częstotliwościach, mogą wystąpić kolizje sygnałów, utrata pakietów lub fałszywe wyzwania. [MOES Smart](#) Oznacza to, że atakujący może zagłuszyć kanał RF, uniemożliwiając sterowanie przekaźnikiem pilotem lub przyciskiem.

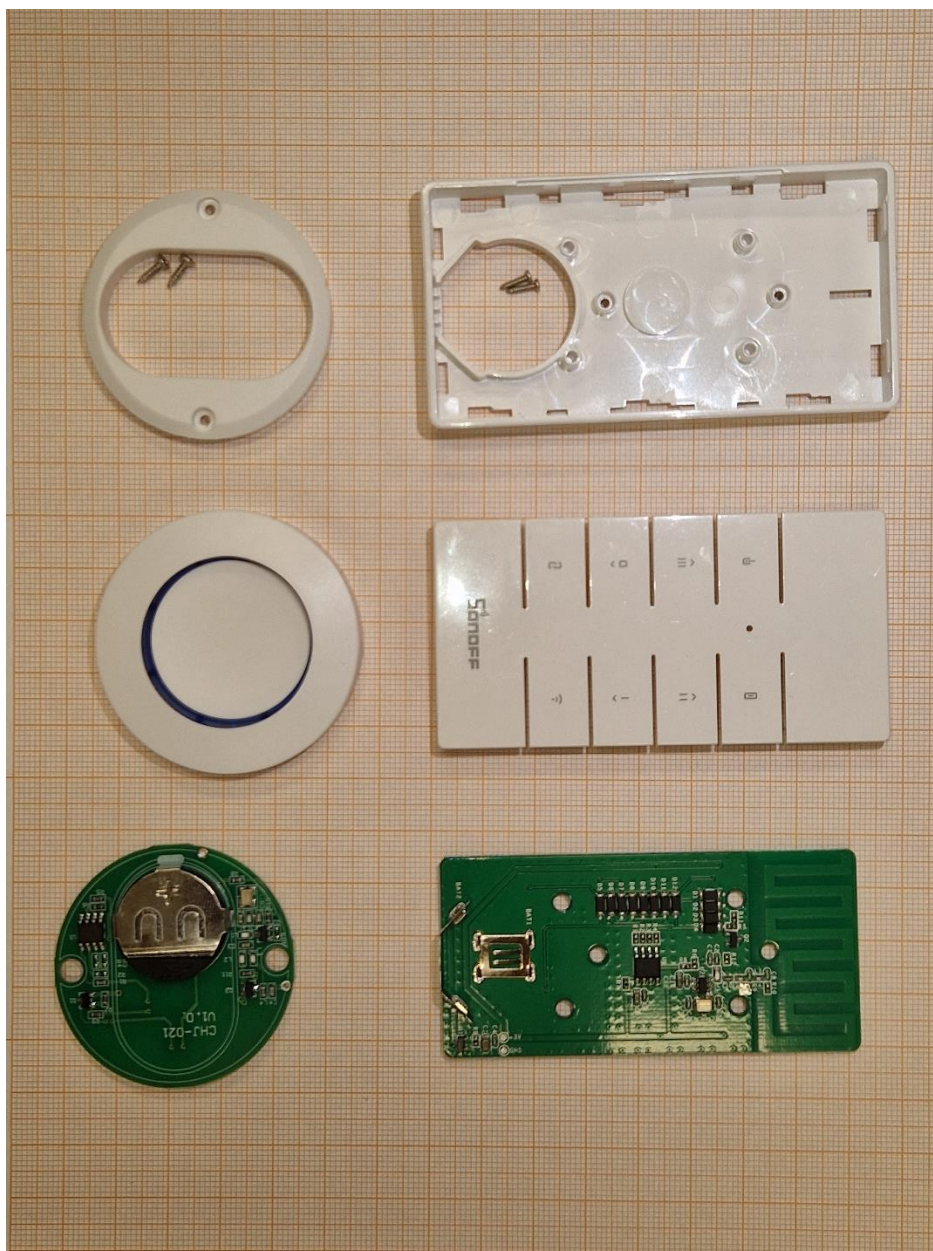
Źródło: [moeshouse.com](#)

3. Analiza systemu metodą inżynierii odwrotnej

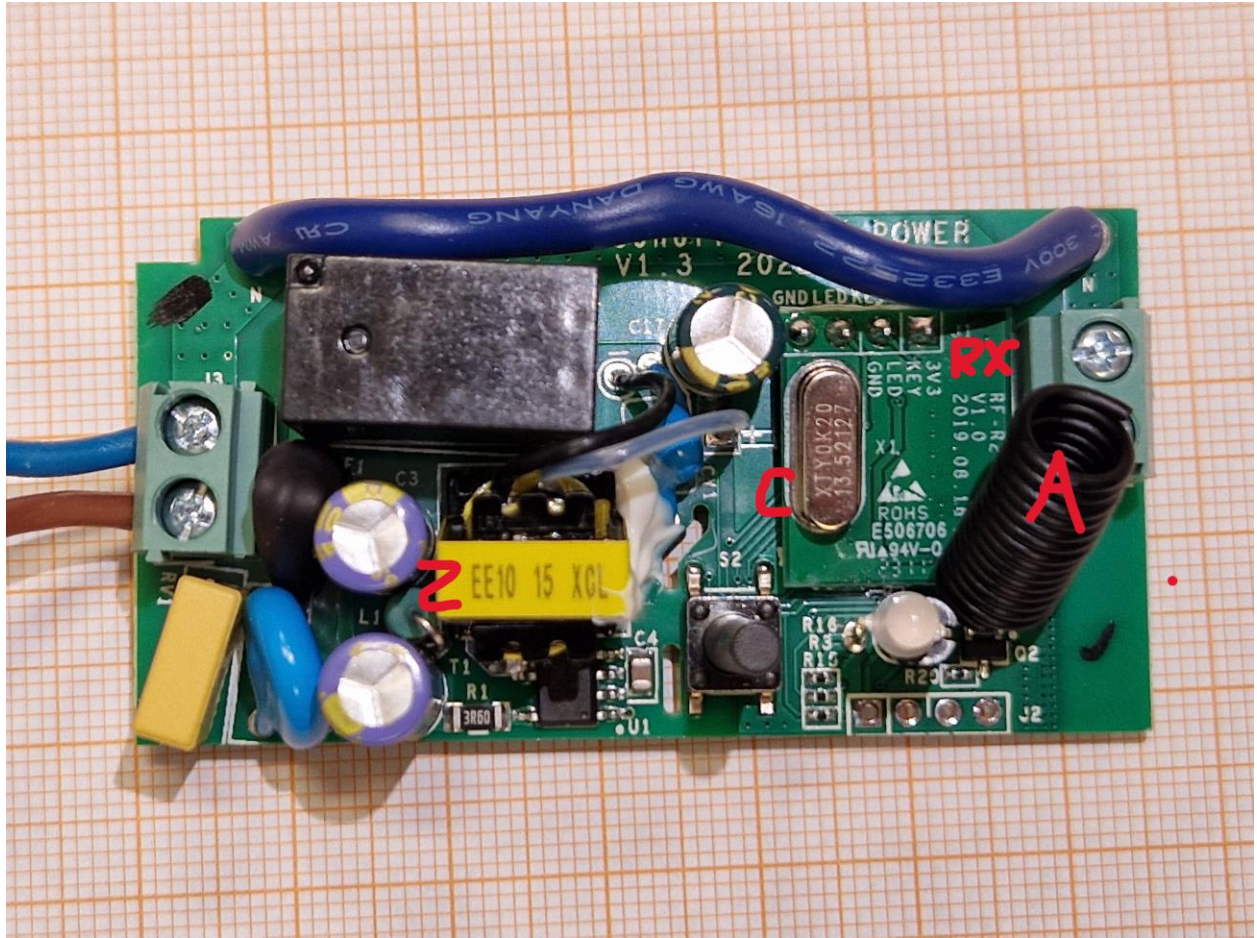


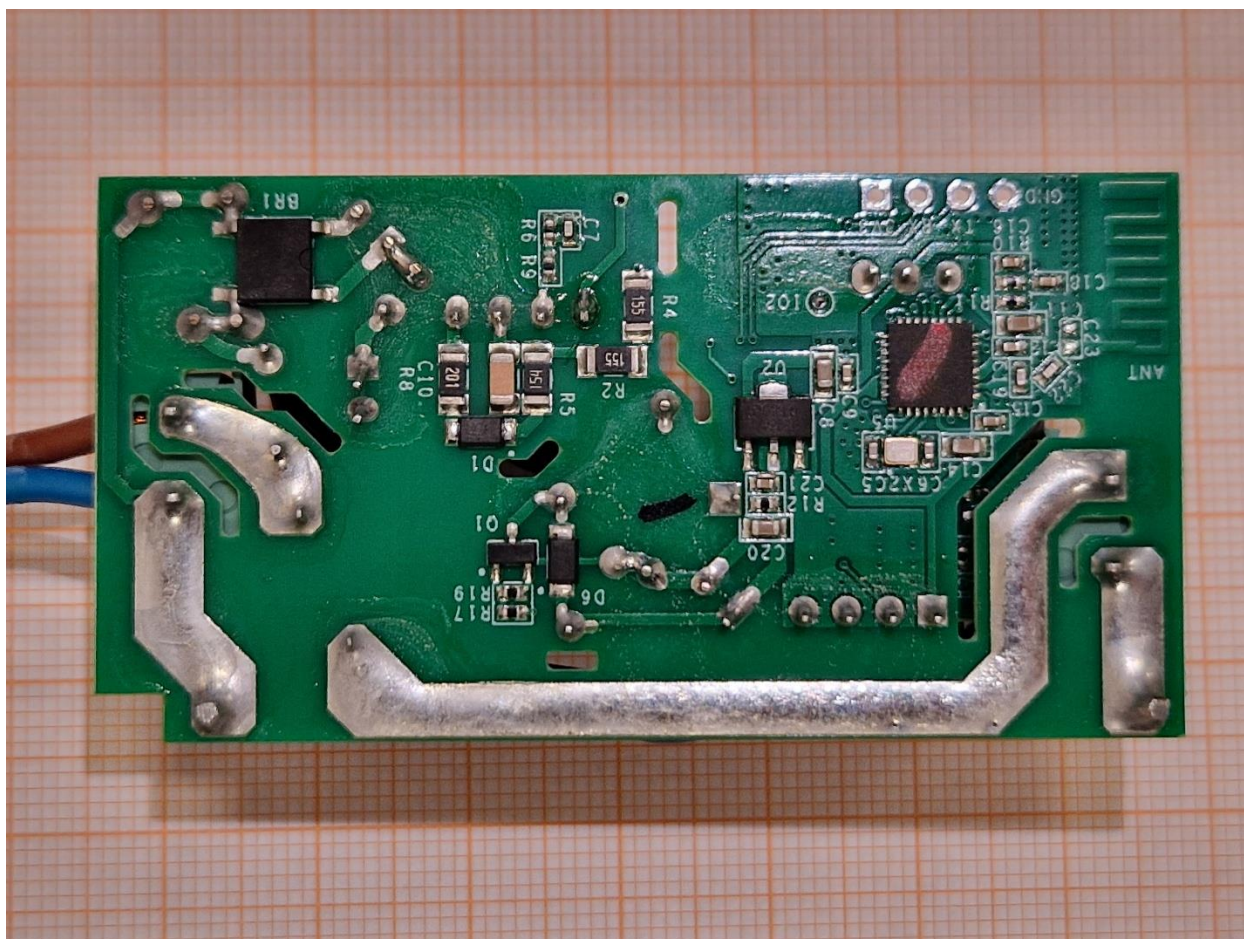
Rys. 3.1 Ogólne zdjęcie systemu





Rys.3.2 Zdjęcie rozkręconego pilota – widok od strony baterii





Rys.3.3 Zdjęcie lampki ze zdjętą obudową

Opis:

Rys.3.1 przedstawia ogólne zdjęcie badanego systemu:

- (P0) Pilot firmy SONOFF,
- (P1) Przycisk,
- (S) Przekaznik Prądu SONOFF

Rys. 3.2 przedstawia zdjęcie rozkręconych pilotów z obu stron. Na zdjęciu można zidentyfikować:

- źródło zasilania (1 bat. CR2016) taki samo dla obu

Rys. 3.3 przedstawia zdjęcie lampki ze zdjętą obudową. Na zdjęciu można zidentyfikować:

- układ scalony nadajnika radiowego E506706 firmy SONOFF (ozn. „RX”)
- spiralną antenę nadawczą o długości ok. 2 cm (ozn. „A”)

- zegar 16Mhz (ozn. „C”)
- transformator impulsowy EE10 15 XCL (ozn. „Z”)

Wnioski:

Rozkręcenie przekaźnika prądu dostarczyło informację o parametry zasilania, długości i pozycji anteny.

4. Analiza warstwy radiowej

Parametry radiowe systemu – Nadajnik okrągły:

- częstotliwość fali nośnej środkowa: 433,718540 MHz
- modulacja: PWM
- szerokość zajmowanego pasma (p. rys. 4.1.): 75kHz
- zasięg deklarowany przez producenta: 30m
- zasięg rzeczywisty: 27m

Parametry radiowe systemu – Nadajnik SONOFF:

- częstotliwość fali nośnej środkowa: 433,903449 MHz
- modulacja: PWM
- szerokość zajmowanego pasma (p. rys. 4.1.): 75kHz
- zasięg deklarowany przez producenta: 30m
- zasięg rzeczywisty: 36m

Rys. 4.1 Widmo przesyłanego sygnału z zaznaczonymi krańcami pasma

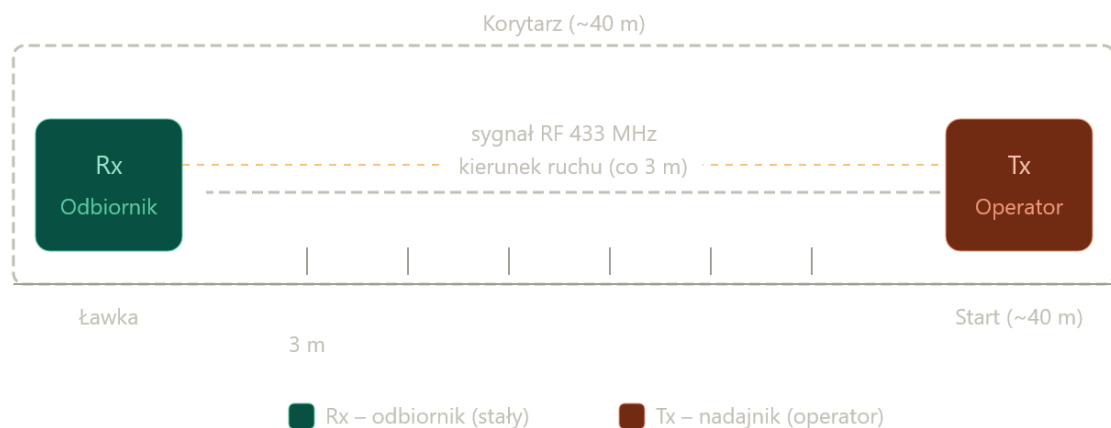
Wpływ dłoni użytkownika na częstotliwość nadajnika:

Nadajnik okrągły: brak wpływu

Nadajnik SONOFF: brak wpływu

Opis procedury pomiaru zasięgu:

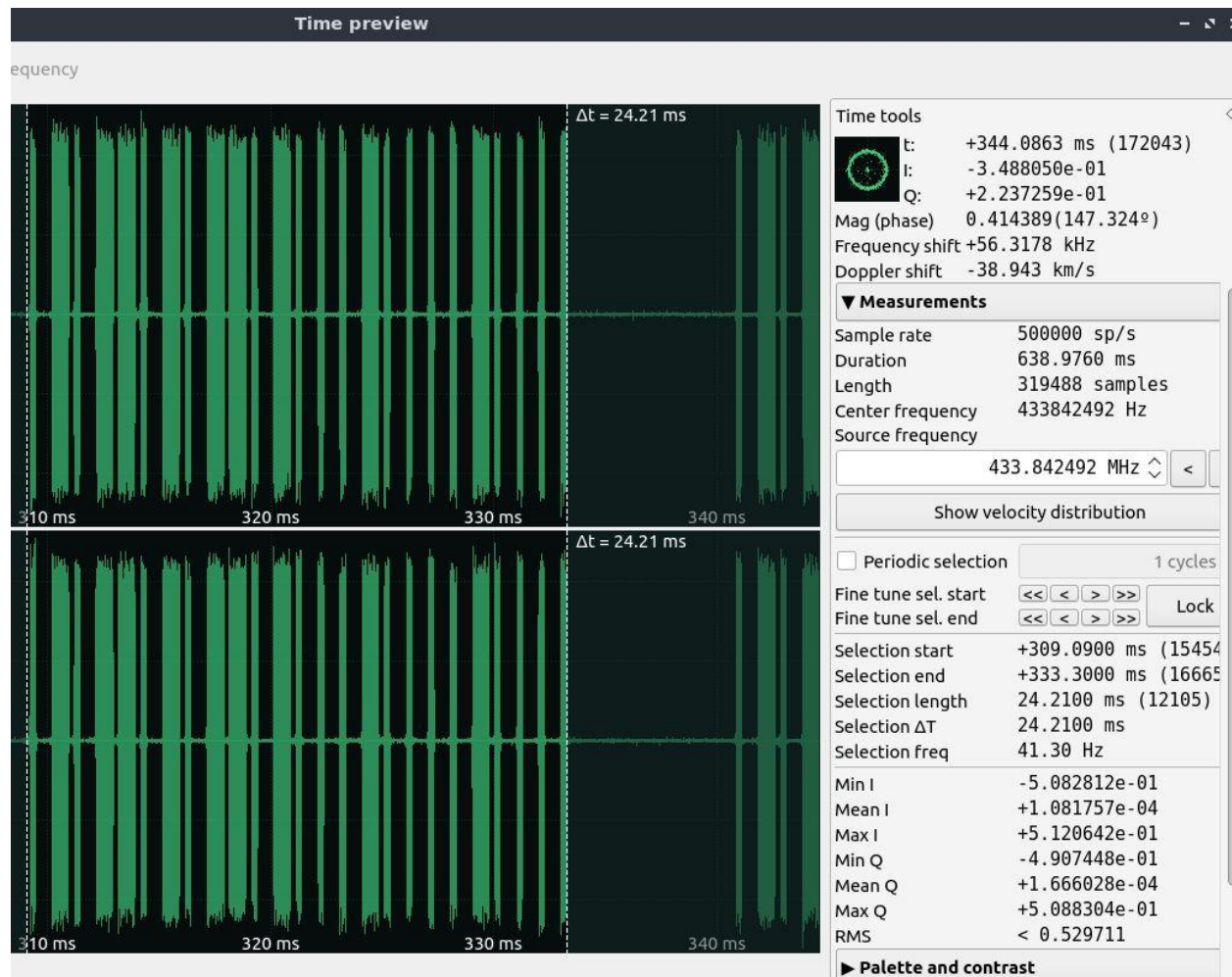
1. Umieszczono odbiornik na ławce w długim pustym korytarzu
2. Operator udał się na koniec korytarza ~40m
3. Operator zaczął przemieszczać się w stronę odbiornika w odstępach 3m
4. Operator zanotował pierwszą odległość w której udało się nadać i odebrać sygnał 7/10 prób

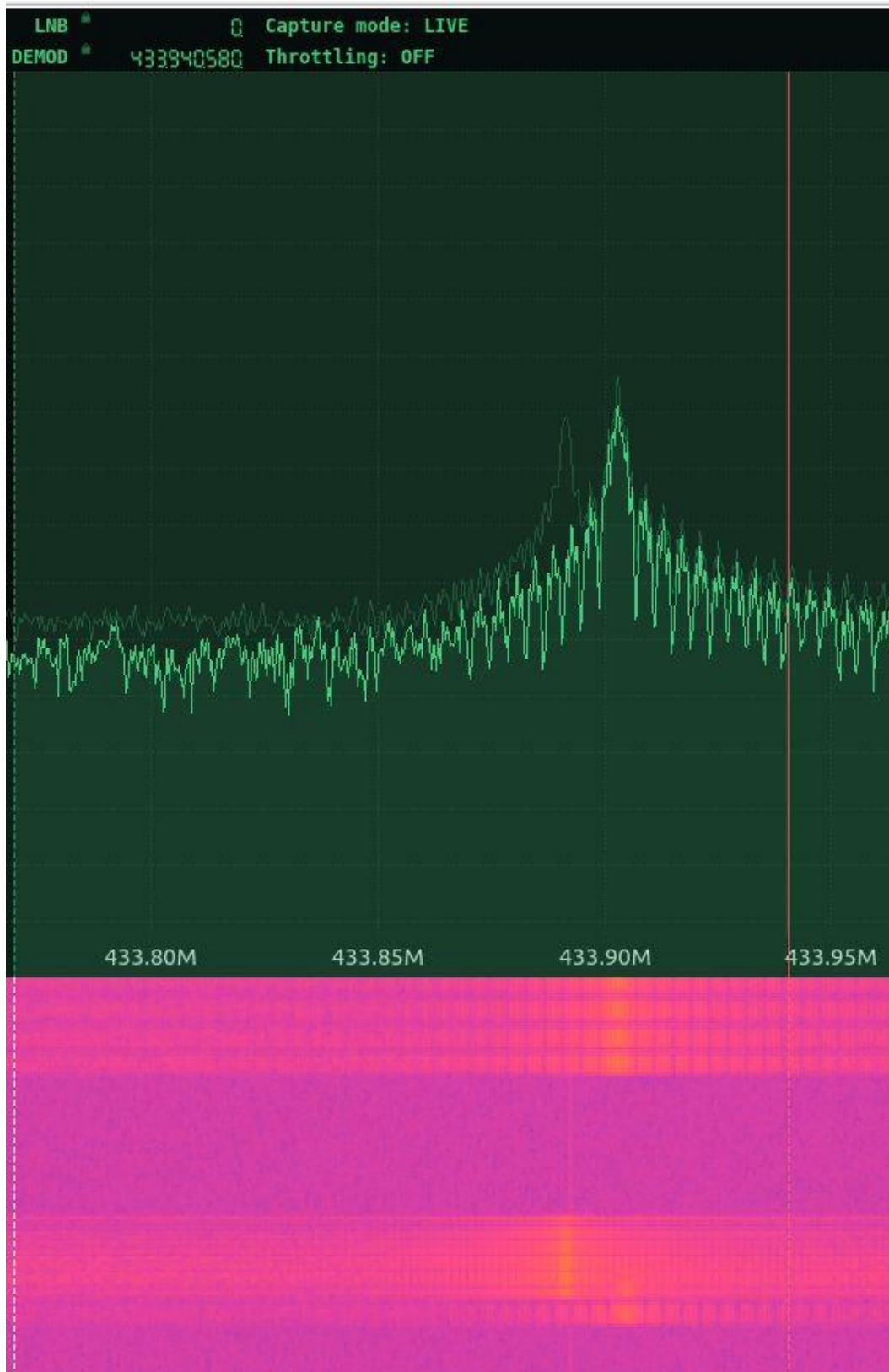


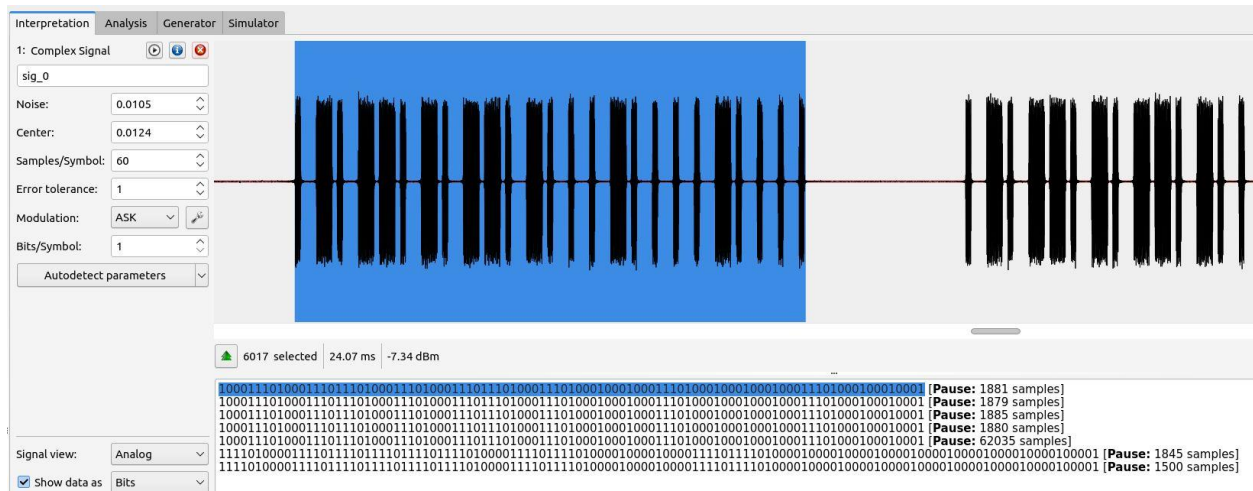
Parametry czasowe depeszy:

- całkowity czas trwania depeszy: Nadaje tak długo jak długo użytkownik trzyma przycisk
- liczba ramek: Zależna od całkowitego czasu trwania
- czas trwania ramki:
 - Dla przycisku 0: 24 ms $\pm$ 0.25ms
 - Dla przycisku 1: 33 ms $\pm$ 0.25ms
- odstęp pomiędzy ramkami:
 - Dla przycisku 0: 7ms $\pm$ 0.25ms
 - Dla przycisku 1: 9ms $\pm$ 0.25ms
- liczba symboli w ramce:
 - Dla przycisku 0: 25
 - Dla przycisku 1: 25
- czas trwania symbolu
 - Dla przycisku 0: 1ms $\pm$ 0.02ms
 - Dla przycisku 1: 1.3ms $\pm$ 0.02ms

Przycisk 0:

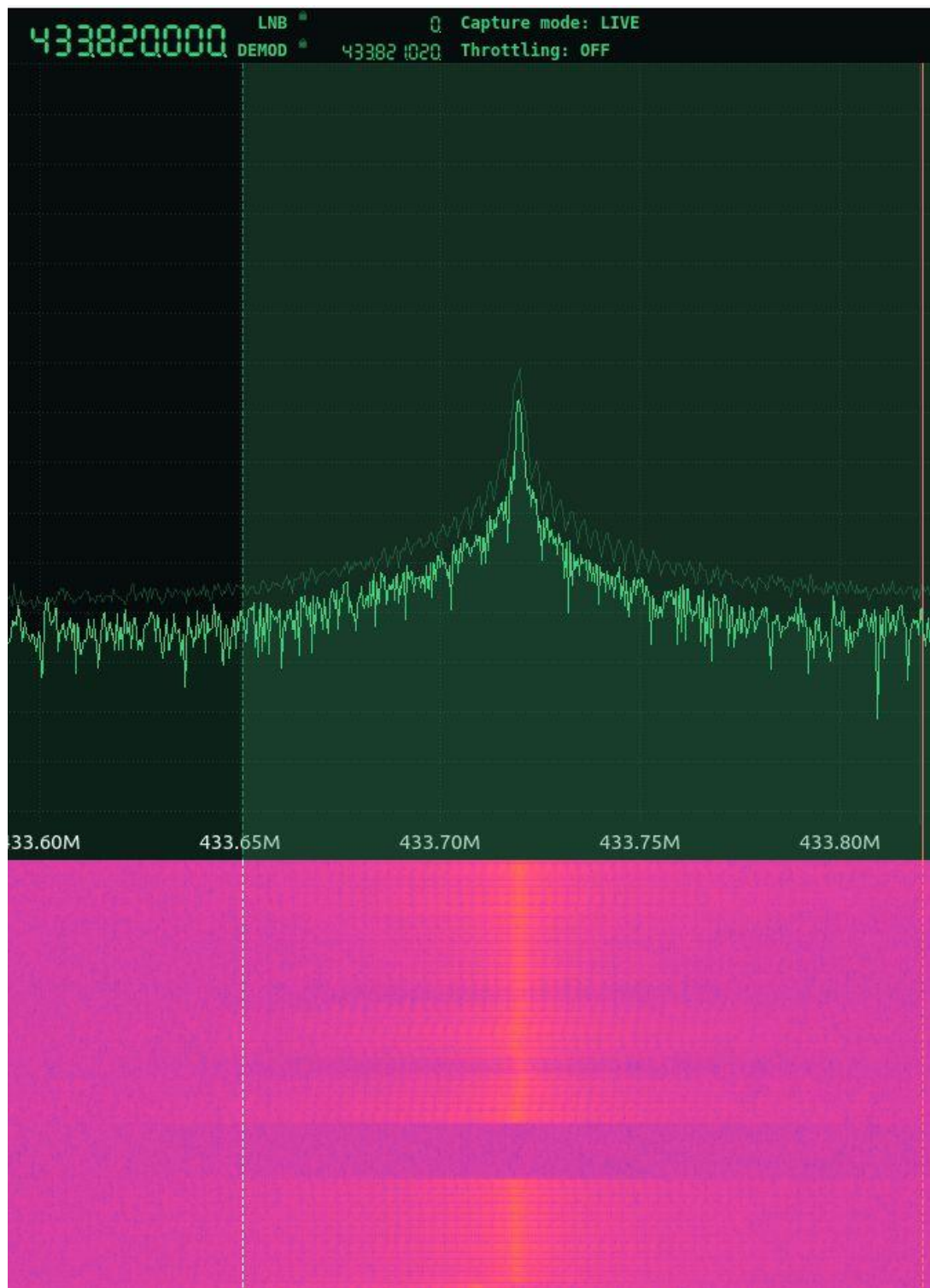


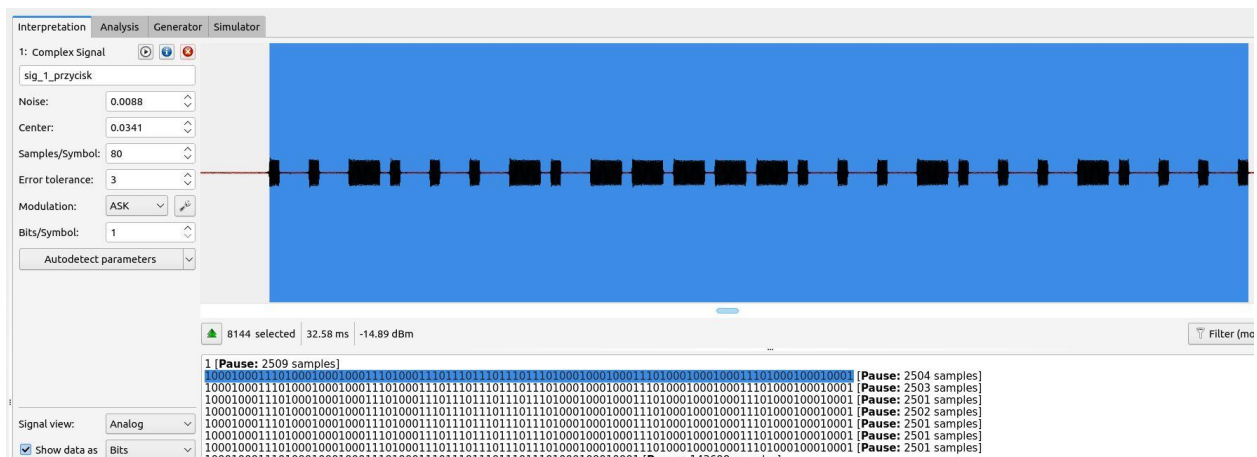




y







Prędkość transmisji:

Nadajnik 0 (przycisk 0)

- Czas symbolu: 1 ms $\rightarrow$ prędkość symbolowa = **1 000 Bd**
- Symboli w ramce: 25, czas ramki: 24 ms $\rightarrow$ czas użyteczny: 25 ms (25 symb. $\times$ 1 ms), odstęp: 7 ms $\rightarrow$ okres ramki: 31 ms
- Prędkość bitowa netto (tylko symbole): 25 bitów / 31 ms = **~ 806 bit/s**
- Prędkość bitowa brutto (sam sygnał): **1 000 bit/s**

Nadajnik 1 (przycisk 1)

- Czas symbolu: 1,3 ms $\rightarrow$ prędkość symbolowa = **~ 769 Bd**
- Symboli w ramce: 25, czas ramki: 33 ms $\rightarrow$ czas użyteczny: 32,5 ms, odstęp: 9 ms $\rightarrow$ okres ramki: 42 ms
- Prędkość bitowa netto: 25 bitów / 42 ms = **~ 595 bit/s**
- Prędkość bitowa brutto: **~ 769 bit/s**

5. Analiza depeszy

Nietypowe elementy depeszy:

Brak zaobserwowanych nietypowych elementów depeszy.

Czy wszystkie ramki danej depeszy są identyczne:

Tak – oba nadajniki wysyłają tę samą ramkę, tak długo jak operator trzyma przycisk. Najmniej udało się przesłać 1.5 ramki. Po przeprowadzeniu testów ustanowiono, że do skutecznego przesłania informacji należy przesłać przynajmniej 3 ramki. Niemniej jednak system potrafił reagować już na jedną ramkę.

Procedura testowa polegała na jak najkrótszym przytrzymaniu przycisku i jednoczesnym przechwyceniu sygnału. Przechwycony sygnał zestawiono z reakcją odbiornika.

Ramka:

Przycisk 0:

10100010100101110111101111

Przycisk 1:

110111010000011101110111

Liczba Przechwyconych Ramek (min 1)	Reakcja odbiornika
< 3	Sporadyczna reakcja
>= 3	Zawsze reakcja

Elementy składowe ramki:

Na podstawie ograniczonego zestawu nie udało się określić dokładnie elementów ramki. Na podstawie porównania ramek z dwóch oddzielnych nadajników udało się wysnuć hipotezę.

Hipoteza:

Początek nadawanej ramki stanowi numer identyfikacyjny nadajnika (nadawca). Następna część – taka sama dla dwóch nadajników – stanowi adres odbiorcy (odbiornik w systemie)

Stały ciąg bitów:

101110111

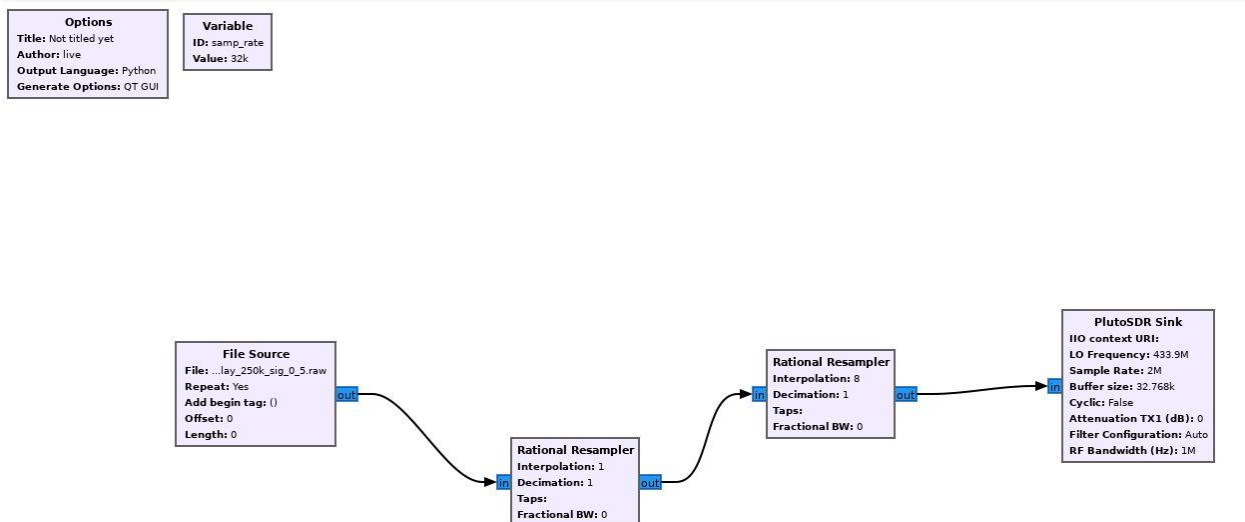
6. Analiza podatności na wybrane typy ataków.

Uwaga: W tej części należy udokumentować przeprowadzenie co najmniej trzech typów ataków. Opis środowiska badań, bez faktycznego opisu eksperymentu będzie nie wystarczający.

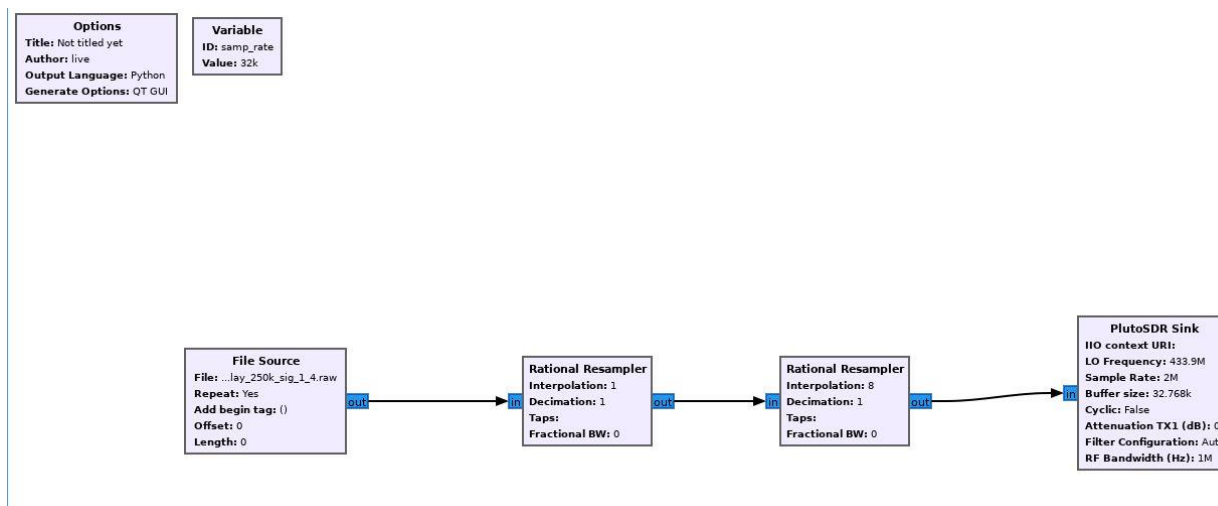
Atak typu REPLAY

Do przeprowadzenia ataku typu Replay nagrano sygnał z nadajnika dwóch pilotów. Następnie w programie audacity przygotowano 3 pliki '.raw'. Każdy z plików zawierał 3, 4 lub 5 ramek. Dla obu pilotów odtworzono nagrania. Do odtworzenia nagrań wykorzystano GNU Radio Companion, w którym wybrano jako źródło wspomniane pliki. Pliki były nagrane na 250k sampling, więc dokonano interpolacji w 2M, aby przygotować sygnał do nadawania przez PlutoSDR 2M sample, 433.9Mhz. Zmieniano każdy z plików jak udało się jednocześnie określić, który z nich dał poszczególnych pilotów skutecznie dokonuje ataku.

Konfiguracja dla przycisku 0:



Konfiguracja dla przycisku 1:



Parametry konfiguracji odbiornika:

Parametry konfiguracji odbiornika: 433.92Mhz

Komentarz po przeprowadzonym ataku:

Podczas testowania ataków typu replay ustalono, że przesunięcie pasma o -250 kHz oraz +450 kHz stanowi graniczną wartość działania odbiornika. Po przekroczeniu tych zakresów dalsza praca w układzie nadajnik-odbiornik okazała się niemożliwa.

Spowolnienie nadawania próbki o współczynnik 2,7 stanowi graniczną wartość poprawnego działania odbiornika podczas odtwarzania sygnału.

Zwiększenie prędkości nadawania próbki o 2.5 razy stanowi graniczną wartość poprawnego działania odbiornika podczas odtwarzania sygnału

Dla 1 pilota (prostokątnego, przycisk 0)

Minimalna liczba ramek: 5

Dla 2 pilota (okrągłego, przycisk 1)

Minimalna liczba ramek: 4

Odporność systemu na zakłócanie

Komentarz po przeprowadzonym ataku:

Korzystając z GNU Radio Companion dokonano ataku typu Jamming. System pozwalał przeprowadzić 4 rodzaje ataków: Szeroko pasmowy, pasmowy, nadawanie nośnej oraz z pliku. W eksperymencie zastosowano 3 pierwsze rodzaje zagłuszania.

Szeroko pasmowy:

Atak szerokopasmowy okazał się skuteczną metodą zakłócania badanego odbiornika. Nadajnik zagłuszający bez dokonania zmian w mocy sygnału skutecznie zaburzał pracę systemu. Okazjonalnie urządzenie było w stanie odebrać sygnał, jednak zwiększenie mocy zgłuszania od 3dB całkowicie uniemożliwiało odbieranie.

Atak pasmowy:

Atak pasmowy ustawiony na 433.9Mhz był bardzo skuteczny w zakłócaniu odbioru. Jakąkolwiek próba poprawy po przez zmianę pozycji odbiornika i nadajnika okazała się kompletnie nieskuteczna. Na tak małej powierzchni zestawionego systemu nie dało się wznowić poprawnej pracy systemu.

Atak nadawania nośnej:

Nadawanie nośnej również był skutecznym atakiem na badany odbiornik. W realnej sytuacji atak byłby na tyle skutecznym, aby określić system mianem niesprawny. Były jednak instancje, w którym udawało się sygnałowi nadawczemu „przebić” się do odbiornika, jednak było to praktycznie bezużyteczne.

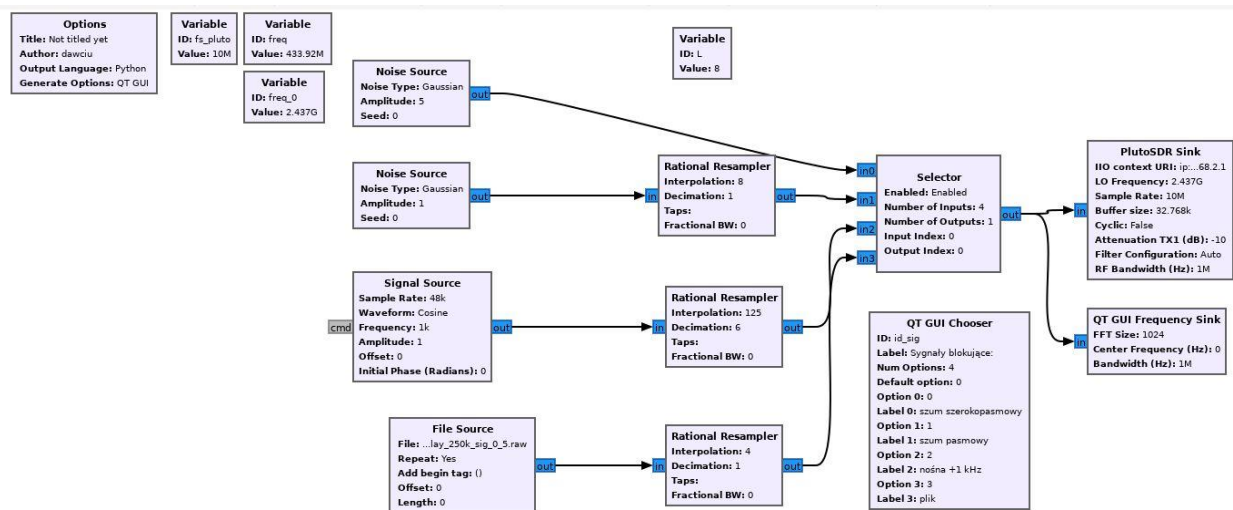
Komentarz:

Badany odbiornik jest minimalnie lub wcale nie zabezpieczony przed atakami typu Jamming.

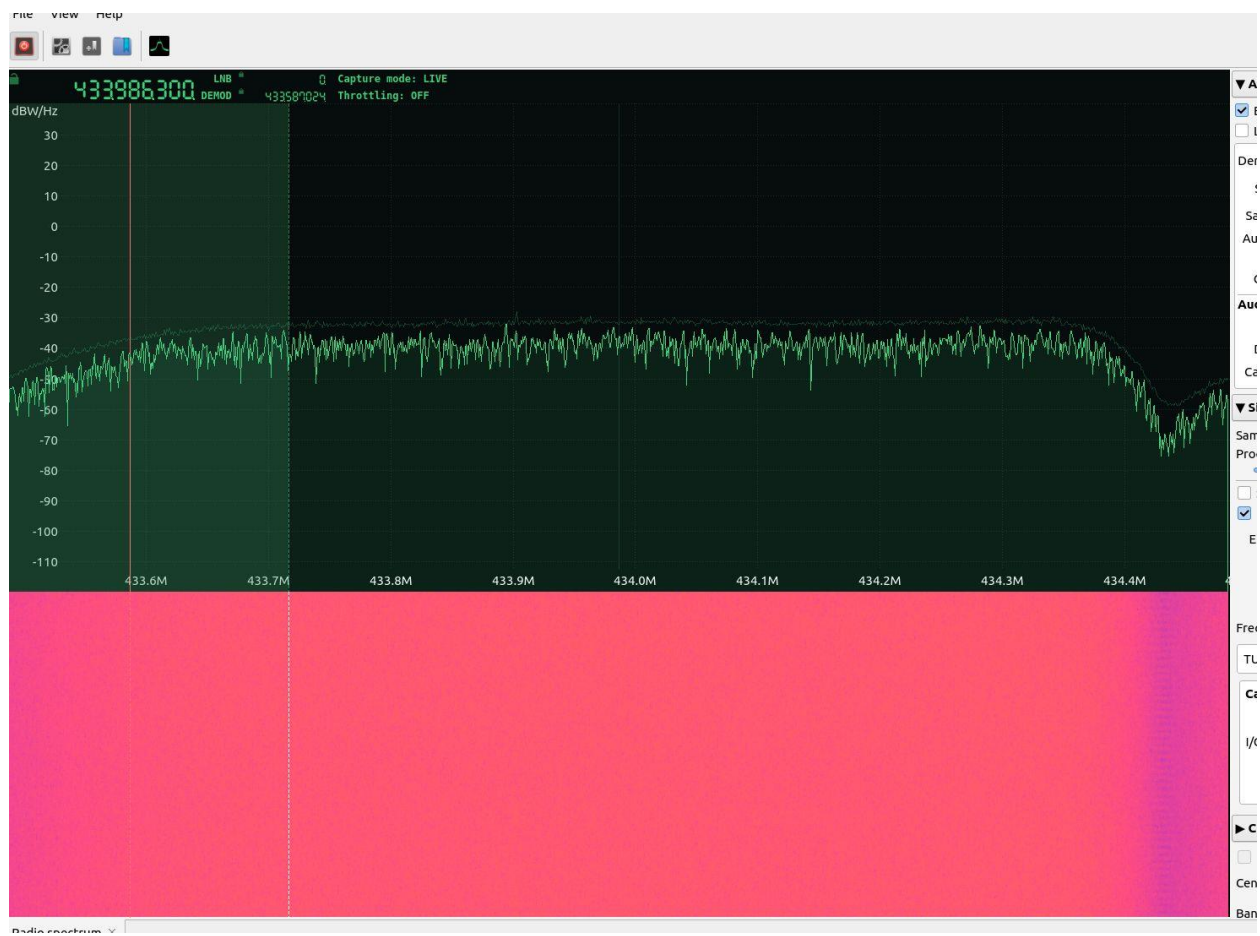
Wpływ modyfikacji parametrów sygnału na skuteczność zagłuszania:

Zbadano wpływ zmiany zysku anteny (attenuation) na skuteczność zagłuszania. Sprawdzano wartości z zakresu <-15, 15> dB. Z racji na już wysoką skuteczność ataku, modyfikacja zysku anteny nie wykazała dużego wpływu na zakłócanie obieranego sygnału. Sygnał pozostawał zagłuszony.

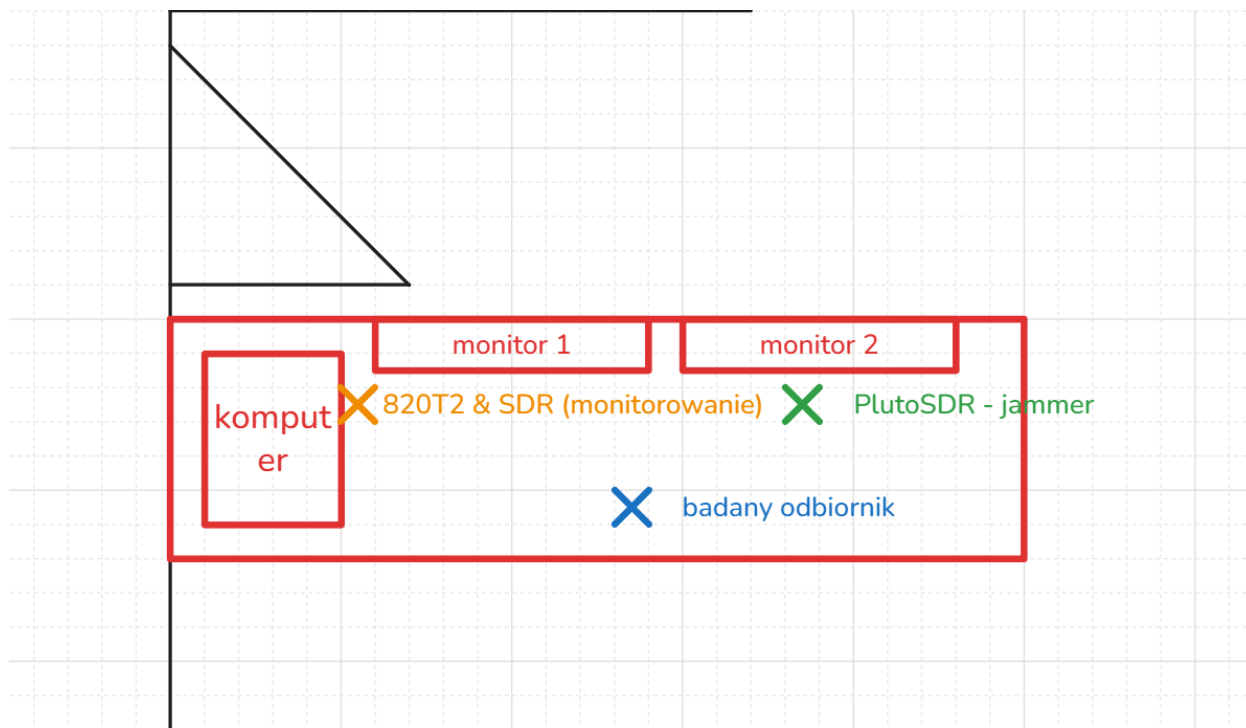
Zbadano wpływ zmiany parametrów ataku pasmowego. Poszerzenie pasma ataku jednocześnie zmniejszało moc nadawania, co zmniejszyło skuteczność ataku. Niemniej jednak atak pozostawał dostatecznie skuteczny – uniemożliwiał poprawną pracę systemu.



Aplikacja GNU Radio Companion do ataku typu jamming:



Zagłuszenie szeroko pasmowe



Układ badawczy

Atak typu BF

Wyliczyć ile prób wymaga pełny atak BP. Wyznaczyć na podstawie analizy budowy ramki z poprzednich punktów ile trwa transmisja elementarnej ramki a następnie oszacować ile trwa taki atak.

Następnie założyć, że znana jest część klucza o postaci: Opracować nadajnik do przeprowadzenia ataku BF w GNURadio Companion.

Zamieścić opis procedury ataku wraz ze stosownymi zrzutami ekranów z użytych programów. Wyniki skomentować.

Rozwiązanie:

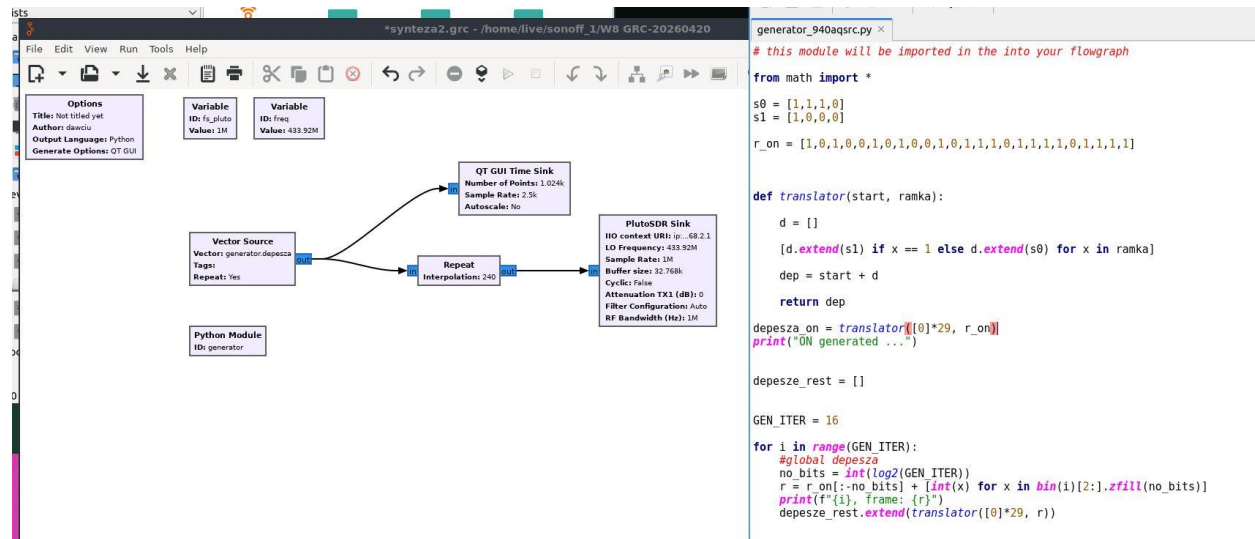
Liczba prób= 33,554,432 (liczba możliwych kombinacji)

Transmisja elementarnej ramki = 31,5 ms, czyli przerwa plus nadanie 25 bitów.

Cała ramka posiada 25 bitów, a więc pełna liczba kombinacji wynosi: $2^{25} * 97,5 \text{ ms}$ (nadanie 3 ramek czyli minimalnej liczby po której odbiornik reaguje) = 37,86 dnia

Zakładamy, że znamy początkową część klucza: 1010001010010111011110, a zgadujemy 4 ostatnie bity czyli 16 kombinacji.

Za pomocą programu GNU radio companion syntezywalimy sygnał o zmiennych 4 ostatnich bitach. Za pomocą analizy pasywnej zaobserwowaliśmy brak zmian w wyglądzie ramki, więc na potrzeby eksperymentu zakładamy zmianę w 4 ostatnich bitach.



Synteza Sygnału – Atak typu Brute Force – GNU Radio Companion z dedykowanym modułem Python generującym zestawy ramek

7. Wnioski i rekomendacje.

Podsumowanie prac. Wnioski i rekomendacje jak można zabezpieczyć badany system.

Dodatek 1. Archiwum sygnałów radiowych.

Dokładny opis AKTUALNEJ struktury archiwum sygnałów radiowych. Drzewo katalogów. Zawartość katalogów: pliki sygnału, pliki metadanych, czas i cel wykonania nagrania, np. „akwizycja depeszy przesyłanej po naciśnięciu przycisku X”.